One Canonical Identity, Different Policy Outcomes

A Bounded Measurement of JSON Receipt Semantics

Pranav Bhave

Abstract

Signed JSON evidence commonly assigns an identity after parsing and canonicalization. That identity is useful only to the extent that the distinctions it removes are irrelevant to the decisions for which the evidence is later used. We report a bounded measurement of that condition for a JavaScript-style receipt canonicalizer, selected version-pinned third-party engines, and explicitly declared adversarial inputs. In a curated 31-class census, the unguarded receipt path collapsed 5 intended distinctions; raw-text admission eliminated those collapses in the same census. Four external canonicalizer ecosystems each showed 4 unintended members, with duplicate-key cases shared across all four. Under author-supplied equality policies, named third-party engines produced 8 decision-split cells for pairs that one receipt identity merged. A separate, opportunity-limited sample of 3,000 Rekor index draws yielded 64 eligible payloads and observed no selected pathologies. Thus the paper establishes neither traffic prevalence nor a deployed application failure. Its contribution is a reproducible measurement boundary: the observed behavior is conditioned on a canonicalizer, an admitted input alphabet, named engine versions, and experiment-authored decisions.

1 Introduction

A digital signature binds a sequence of bytes; a receipt system often binds a derived representation. The difference matters when a raw JSON document is parsed, transformed into a canonical value, and then given one digest or receipt identifier. If two raw documents become one identity while a downstream decision distinguishes them, the identity is too coarse for that declared use. This is a representation question, not a claim that signing establishes the truth of a payload or the quality of an upstream decision.

Canonicalization and semantic divergence are established concerns. I-JSON limits duplicate member names and numeric representations [1]; JCS defines a canonical JSON serialization profile [7]; and the Verifiable Credential Data Integrity recommendation discusses canonicalization and data-loss boundaries [9]. Parser differentials have also been measured broadly: Crossy tested 22 JSON parsers across languages [4]. More generally, signed-document and multi-parser work has demonstrated that a valid signature can coexist with divergent interpretation [6, 10]. Recent work explicitly frames canonicality relative to downstream semantic equality [2]. We therefore do not present a new canonicalization theory, a JSON-parser discovery, or a new receipt format.

Instead, we ask one constrained empirical question:

> *For a named receipt identity, declared input alphabet, and selected version-pinned decision engines, do merged documents always induce the same experiment-authored decision?*

The answer in this measurement is no for selected constructions, and yes for the E12 sampled payload slice with respect to the tested constructions. Those two findings must stay together. Constructibility does not imply incidence; a null observation in a narrow corpus does not establish absence elsewhere.

Contributions. This paper makes four bounded contributions.

1. It states a decision-conditioned measurement protocol for JSON receipt identity, separating raw document equality, canonical identity, and a named downstream decision.
2. It reports a controlled census and seeded probe for the Ghost-Ark JavaScript-style canonicalizer, plus a selected external canonicalizer census.
3. It shows concrete decision differences under author-supplied policy-engine executions, while explicitly separating that consequence census from deployed relying-party evidence.
4. It treats a negative, opportunity-limited DSSE payload observation as first-class evidence and supplies an evidence binder that ties all numerical macros to frozen source anchors.

2 What is measured

Let x be raw JSON text. A receipt pipeline accepts x only when $x \in \Sigma$, then parses and canonicalizes it to $\mathsf{canon}(x)$, and assigns $\mathsf{ID}(x) = H(\mathsf{canon}(x))$. A selected engine $p \in \mathcal{P}$ executes an author-supplied decision function $\mathsf{D}_p(x)$ over the document under a version-pinned implementation and policy. The measurement seeks pairs (x, y) for which

$$x, y \in \Sigma \quad \wedge \quad \mathsf{ID}(x) = \mathsf{ID}(y) \quad \wedge \quad \mathsf{D}_p(x) \neq \mathsf{D}_p(y).$$

This notation is only a compact description of the experiment. It does not assert a new theorem, an exhaustive consumer model, or a property of all JSON software.

Figure 1 depicts the distinction. A receipt identity can be appropriate for one decision relation and too coarse for another. The input alphabet is equally important: rejecting ambiguous raw texts before canonicalization can eliminate a measured collapse, while accepting a larger alphabet can introduce one.

2.1 Boundary and threat model

The study evaluates a local parse–canonicalize–digest path and explicit third-party command-line or library arms. It does not evaluate a deployed receipt consumer, a cloud authorization path, cryptographic key custody, or agent behavior. An observed decision split says only that a selected engine under a policy written for this experiment distinguishes two inputs that the chosen receipt path merges. It is not an observed production authorization failure.

The adversarial corpus includes malformed or ambiguity-bearing JSON constructions such as duplicate keys, numeric representations, and string edge cases. It is curated for diagnostic contrast, not sampled from ordinary traffic. The E12 arm is intentionally different: it samples a defined supply-chain payload slice and searches it with controls, but its eligibility filter leaves a small, producer-clustered denominator.

3 Measurement design

3.1 Receipt-path census and randomized probe

E1 enumerates 31 predeclared pathology classes through the Ghost-Ark receipt path. An unintended kernel member is a pair that canonicalizes to the same identity despite being marked distinct by the experiment's intended-value relation. The unguarded arm found 5 such members. A strict raw-text admission arm found 0 and had 0 rejection-asymmetry cases in this census.

E1-B supplements the curated census with a declared seeded adversarial generator. The unguarded arm found 403/767 collapses (52.5%, Wilson [49.0%, 56.1%]); strict admission found 0/767 (0.0%, Wilson [0.0%, 0.5%]). These intervals describe repeated draws from that generator, not user traffic or a general security rate.

3.2 External canonicalizer and differential arms

E7 generates 1,500 seeded inputs across V8, CPython, and jq, finding 8 structural divergence classes over 4 mechanisms. Every pair of those selected arms disagreed somewhere. E11 asks a narrower portability question using 4 canonicalizer ecosystems that this project did not author: Rust `serde_json`, Ruby JSON, CPython JSON, and `jq -S -c`. Each had 4 unintended members in the same 31-class diagnostic census. Three duplicate-key classes were shared across all arms; no third-party arm exhibited the 2^{53} construction, which confines that numeric observation to a double-backed model rather than the JSON data format generally.

3.3 Decision consequence and ecological control

E16 evaluates six curated pairs against four version-pinned engines under author-supplied equality policies. It records 8 engine–pair decision splits. The decimal-literal pair split OPA, CUE, and jq; the 2^{53} pair split all four engines; CUE alone distinguished the selected duplicate-key pair; and a trailing-zero pair supplied a same-decision discriminator. This establishes a selected consequence existence result. It does not establish that those engines consume Ghost-Ark receipts or that a deployed policy would make the same choice.

E12 supplies the counterweight. From 3,000 uniform Rekor index draws, only 64 `intoto` payloads were eligible for the selected scan, spanning 16 clustered producers. The observed count was 0/64 for the tested pathologies; all 7 detector controls fired and all eligible payload hashes matched. This is a constructible-but-not-observed result for an era-skewed, opportunity-limited slice. It is not a prevalence estimate, a producer-level estimate, or evidence of a DSSE weakness: DSSE signs raw payload bytes [3].

3.4 Composition as supporting evidence

E13 evaluates whether a downstream stage can separate two accepted inputs already collapsed upstream. Its finite model covers 625 hops and 390,625 compositions, with 0 repairs by separation. The implementation arm records 2 forward counterexample cells, both relying on a non-default CPython `surrogatepass` codec before jq. No all-default pair reproduced that implementation result. We therefore retain composition as supporting placement evidence rather than a headline deployment claim.

4 Results and interpretation

The measurements show three distinct facts.

A raw-text boundary changes the measured result. Within the declared pathology corpus and generator, strict admission removed the measured unintended merges. This is a result about that admission policy and alphabet; it does not assert conformance to JCS, I-JSON, or any other profile. Standards such as I-JSON and JCS remain useful comparison points, not properties attributed to the local implementation [1, 7].

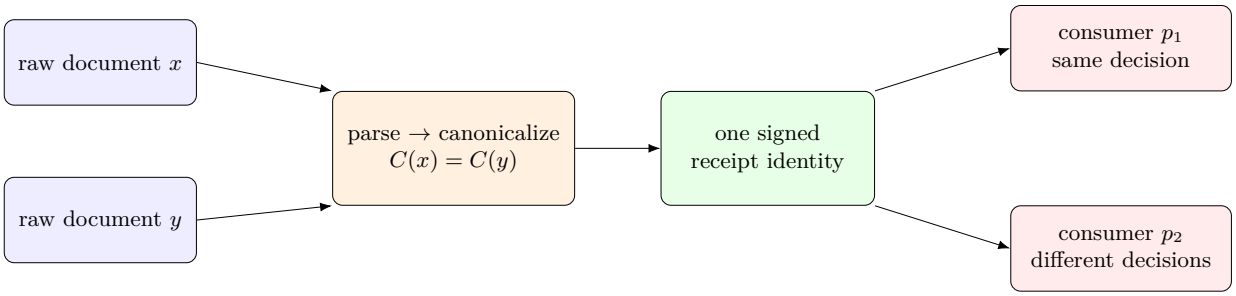


Figure 1: Measurement model. The lower decision branch is an observed possibility in the selected experiments, not a rate or a universal behavior.

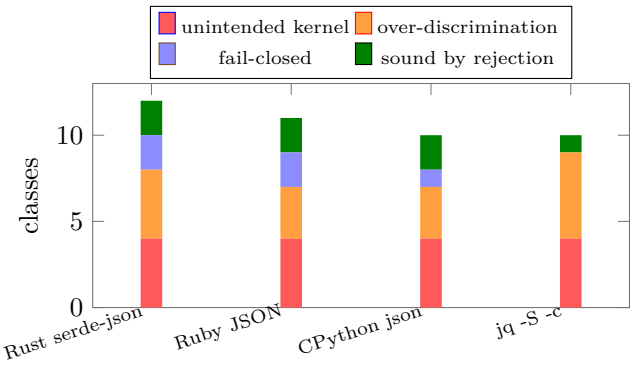


Figure 2: E11 diagnostic classifications across selected external canonicalizer arms. Counts are census members, not ecosystem frequencies.

E12: sampled payload slice

0/64 selected pathologies observed
16 clustered producers

Possible, not observed in this slice.

E16: curated engine census

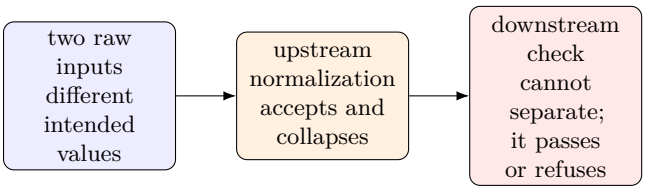
8 decision-split cells across 4 engines
author-supplied equality policies

Consequence exists, not a prevalence estimate.

Figure 3: Two evidence classes kept deliberately separate. E12 is a sampled null observation; E16 is a curated consequence census.

The observation is not confined to one implementation. The E7 and E11 arms show that selected JSON ecosystems induce different equivalence relations and that duplicate-key collapses occur in all four E11 arms. This does not rank libraries, establish exploitability, or measure market adoption. It motivates recording parser, canonicalizer, and policy versions with any receipt claim that relies on their interpretation.

One identity can induce different selected decisions. E16 connects identity collapse to a concrete decision distinction. The result's strength is existential and controlled: named, released engines made different outputs under policies we authored. Its weakness is equally clear: there is no independently maintained receipt-relying application in the measurement. This is why the E12 null result is central rather than an appendix footnote.



E13's finite model found 0 repairs by separation. Its 2 implementation counterexample cells require a non-default permissive codec; no all-default pair reproduced it.

Figure 4: E13's supporting placement boundary. The reported implementation cells require a selected non-default codec configuration.

5 Relation to prior art

The closest conceptual prior work is Brömme's treatment of canonicalization failure as representation divergence relative to relevant semantic equality [2]. Our delta is not a new semantic-equality criterion. It is the bounded package of (i) a receipt-path identity measurement, (ii) version-pinned decision executions, and (iii) an ecological null arm reported alongside selected counterexamples.

Cross-language JSON testing already supplies broader parser-differential coverage [4]. We use differential behavior only as a diagnostic component of a receipt-identity study. Similarly, semantic gaps between signed document consumers [6] and archive parsers [10] rule out a general signature-versus-semantics novelty claim. We do not claim one.

Standards and format work also constrain the scope. JCS and I-JSON give existing JSON representation profiles [7, 1]; the W3C data integrity work treats transformation-related data loss as a design concern [9]; EverParse demonstrates mechanically checked parser/serializer methods for authenticated formats [5]. The independent Vaara Receipt draft occupies

nearby recomputable-receipt territory [8]. These works strengthen the case for narrow measurement language, not a new receipt architecture claim.

6 Evidence provenance

The paper is intentionally isolated from the repository's existing transaction-control manuscript. Its source anchors are the annotated `evidence-v1` and `v1.0.0` revisions recorded in `evidence-manifest.v1.json`. The `paper-next-evidence` gate verifies that those tags still resolve, that each documented experiment heading exists at the frozen evidence revision, that generated numerical macros match `evidence-manifest.v1.json`, and that required citations resolve.

The gate does not replay E12, E13, or E16. Their generated reports are ignored local artifacts rather than files in the tagged release. Exact results are therefore tied to the frozen experiment record and source anchors, with this limitation exposed rather than silently converting local output into a release bundle. This is a reproducibility aid, not independent replication.

7 Limitations and the decisive next experiment

The evidence is bounded in five ways. First, the pathology corpus is curated. Second, E1-B's confidence intervals are conditional on its declared generator. Third, E11 covers four selected external arms, not their ecosystems. Fourth, E12 has 64 eligible payloads from 16 clustered producers and does not create a traffic denominator for every pathology. Fifth, E16's policies and equality rules were authored for the experiment, and its report does not record a usable host identifier.

The result is therefore unsuitable as a main-track systems or agent-governance paper on the frozen artifact alone. The single experiment most likely to change that assessment is preregistered measurement of one independently maintained signed structured-data ecosystem with an actual canonicalization–reparse boundary, versioned external consumers, a strict-rejection control, and producer-aware population accounting. The target should not be DSSE itself: its raw-byte signing model makes E12 a corpus arm, not a target weakness.

8 Conclusion

For the selected JSON receipt path, one canonical identity can cover two raw documents that named engines distinguish under author-supplied policies. The same study found none of its selected constructions in a limited DSSE payload slice. These are jointly useful facts: they locate a representation boundary without promoting a curated counterexample into a prevalence claim. A receipt claim should name the canonicalizer, accepted alphabet, and downstream decision relation that its identity is intended to preserve.

References

[1] Tim Bray. The I-JSON message format. RFC 7493, RFC Editor, March 2015.

[2] Arslan Brömme. Canonicalization failures as a recurring vulnerability class: Representation divergence in cryptographic systems and its avoidance. *arXiv preprint arXiv:2608.06508*, 2026.

[3] in-toto Project. Dsse v1 envelope specification. Project specification. Accessed 2026-08-24.

[4] Jonas Möller, Felix Weißberg, Lukas Pirch, Thorsten Eisenhofer, and Konrad Rieck. Cross-language differential testing of JSON parsers. In *Proceedings of the 19th ACM Asia Conference on Computer and Communications Security*, pages 1117–1127, 2024.

[5] Tahina Ramananandro, Antoine Delignat-Lavaud, Cédric Fournet, Nikhil Swamy, Tej Chajed, Nadim Kobeissi, and Jonathan Protzenko. Everparse: Verified secure zero-copy parsers for authenticated message formats. In *28th USENIX Security Symposium (USENIX Security 19)*. USENIX Association, August 2019.

[6] Simon Rohlmann, Vladislav Mladenov, Christian Mainka, Daniel Hirschberger, and Jörg Schwenk. Every signature is broken: On the insecurity of microsoft Office's OOXML signatures. In *32nd USENIX Security Symposium (USENIX Security 23)*, pages 7411–7428. USENIX Association, August 2023.

[7] Anders Rundgren, Brian Jordan, and Samuel Erdtman. JSON canonicalization scheme (JCS). RFC 8785, RFC Editor, June 2020.

[8] Henri Sirkkavaara. The vaara receipt: A recomputable receipt format for decisions about agent actions. Internet-Draft draft-sirkkavaara-vaara-receipt-02, Internet-Draft, June 2026. Work in Progress; independent submission, not endorsed by the IETF.

[9] W3C. Verifiable credential data integrity 1.0. W3c recommendation, World Wide Web Consortium, May 2025.

[10] Yufan You, Jianjun Chen, Qi Wang, and Haixin Duan. My ZIP isn't your ZIP: Identifying and exploiting semantic gaps between ZIP parsers. In *34th USENIX Security Symposium (USENIX Security 25)*, pages 431–450. USENIX Association, August 2025.